DuocUC | ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

SISTEMA ATLAS

Informe de seguridad y calidad en el desarrollo de software

Integrantes:
Joaquín Beltrán
Lucas Soto

Sección: ISY1102_001V

Carrera: Ingeniería en Informática

Docente: Juan Guillermo Azócar

Fecha: 09 de septiembre de 2026

INDICE

INDICE....2
1. Introducción....2
2. Criterios de calidad....3
3. Plan de pruebas....3
    3.1 Estrategia de pruebas....3
    3.2 Tipos de prueba....4
    3.3 Criterios de aceptación....5
    3.4 Herramientas utilizadas....5
4. Diseño de casos de prueba....5
5. Cierre / análisis de cobertura....10

1. Introducción

Atlas es una plataforma web multicapa (Frontend en React, Backend en Express y base de datos PostgreSQL) desarrollada por CreaLab Spa, orientada a pymes chilenas para la gestión de clientes, contratos y documentos asociados. Dado que el sistema administra datos personales, bancarios y contractuales de carácter sensible, resulta indispensable diseñar un plan de pruebas que permita verificar tanto su correcto funcionamiento como el cumplimiento de estándares de calidad, seguridad y normativa vigente antes de su puesta en producción.

- Contexto: Atlas centraliza la administración de empresas, usuarios con roles diferenciados (administrador/editor), clientes y contratos, permitiendo la carga y descarga de documentos asociados a cada contrato.
- Propósito: este plan busca asegurar que los requerimientos funcionales y no funcionales definidos en el ERS se cumplan correctamente, que los controles de seguridad y de acceso por rol funcionen como se espera, y que el sistema cumpla con la normativa chilena de protección de datos personales.
- Contenido: el informe presenta los criterios de calidad exigidos, la estrategia y los tipos de prueba a aplicar, los criterios de aceptación transversales, los recursos y herramientas necesarias, y el diseño detallado de seis casos de prueba representativos.

2. Criterios de calidad

Atlas, al gestionar datos personales, bancarios y contractuales de clientes de pymes chilenas, debe cumplir con los siguientes estándares definidos en el ERS:

- Calidad: interfaz accesible (tipografía legible, contraste adecuado, navegación por teclado, etiquetas ARIA), con especial atención a usuarios adultos mayores; tiempos de respuesta CRUD inferiores a 300 ms y carga de página inferior a 2 s en conexión móvil; soporte de 200 usuarios concurrentes por defecto; disponibilidad objetivo de 99,5% mensual con ventanas de mantenimiento planificadas; y mantenibilidad favorecida por una arquitectura desacoplada (React / Express / PostgreSQL) documentada mediante Swagger.
- Seguridad: comunicaciones cifradas mediante TLS obligatorio, contraseñas hasheadas con bcrypt, cifrado de datos sensibles en reposo, control de acceso por rol aplicado en el backend, protección contra CSRF, XSS e inyección SQL, gestión segura de logs, políticas de respaldo y recuperación definidas, y manejo de sesión mediante tokens JWT de corta vigencia con refresh token.
- Normativas: cumplimiento de la Ley N.º 19.628 sobre Protección de la Vida Privada y su actualización mediante la Ley N.º 21.719 de Protección de Datos Personales, dado que el sistema almacena datos personales y bancarios de clientes; alineación con estándares técnicos como ISO/IEC 25010 (calidad de producto de software) e ISO/IEC 27001 (gestión de seguridad de la información); y políticas internas de CreaLab Spa sobre política de contraseñas (mínimo 12 caracteres, con mayúscula, minúscula, número y símbolo) y control estricto sobre el almacenamiento de documentos por contener información sensible.

3. Plan de pruebas

3.1 Estrategia de pruebas

Las pruebas de Atlas se ejecutarán bajo un enfoque mixto, combinando pruebas manuales y automatizadas, conforme a las siguientes consideraciones:

- Enfoque: mixto. Pruebas manuales exploratorias para flujos críticos de negocio y usabilidad; pruebas automatizadas para regresión, endpoints REST y pruebas de carga.
- Etapas: (1) planificación y análisis del ERS, (2) diseño de casos de prueba, (3) preparación de datos y ambiente, (4) ejecución de pruebas funcionales y no funcionales, (5) registro de defectos y reejecución, (6) cierre y reporte de resultados.
- Herramientas: Postman/Swagger para pruebas de API, Jest y Supertest para pruebas unitarias e integración del backend, Cypress para pruebas end-to-end del frontend, OWASP ZAP para pruebas de seguridad, y k6 o JMeter para pruebas de carga y rendimiento.
- Priorización: primero los requerimientos funcionales esenciales (autenticación, CRUD de clientes y contratos), luego las pruebas de seguridad (control de acceso, aislamiento multiempresa) y finalmente las pruebas no funcionales (rendimiento, usabilidad, compatibilidad).
- Criterios de entrada: ERS aprobado, ambiente de pruebas disponible y datos de prueba cargados. Criterios de salida: 100% de los casos de prueba críticos ejecutados, sin defectos críticos o de seguridad abiertos, y cobertura de endpoints críticos verificada con Swagger.

Cronograma Ejecución:

Etapa	Duración estimada
1. Planificación y análisis del ERS	2 días
2. Diseño de casos de prueba	2 días
3. Preparación de datos y ambiente de pruebas	1 día
4. Ejecución de pruebas funcionales y no funcionales	4 días
5. Registro de defectos y reejecución	2 días
6. Cierre y reporte de resultados	1 día
Total	12 días hábiles

3.2 Tipos de prueba

Se aplicarán los siguientes tipos de prueba sobre Atlas, cada uno orientado a verificar un conjunto específico de requerimientos del ERS:

- Pruebas funcionales: validan el correcto funcionamiento de los requerimientos RF-1 a RF-6 (autenticación, registro y creación de empresa, gestión de usuarios y roles, gestión de clientes, gestión de contratos y documentos, y auditoría).
- Pruebas no funcionales: evalúan atributos de calidad como rendimiento, disponibilidad y compatibilidad definidos en NFR-PERF, NFR-DIS y NFR-COMPAT.
- Pruebas de seguridad: verifican la protección contra CSRF, XSS e inyección SQL, el cifrado TLS, el hasheo de contraseñas, el control de acceso por rol (NFR-SEG-1 a 9) y el aislamiento de datos entre empresas (RB-2).
- Pruebas de integración: comprueban la correcta comunicación entre el frontend en React, la API REST en Express y la base de datos PostgreSQL, por ejemplo la persistencia de un contrato recién creado junto con su documento asociado.

- Pruebas de usabilidad: aseguran que la interfaz sea utilizable por adultos mayores (NFR-USAB-1 a 4), con tipografía legible, controles grandes y un flujo claro de acceso a la información (cliente → contratos asociados).
- Pruebas de rendimiento: validan los tiempos de respuesta CRUD (menores a 300 ms), la carga de página (menor a 2 s en móvil), el soporte de 200 usuarios concurrentes y los tiempos de subida/descarga de documentos (menores a 10 s).

3.3 Criterios de aceptación

De forma transversal, un caso de prueba se considerará aprobado cuando: (1) toda operación de escritura (crear, editar, eliminar) respete el rol asignado al usuario (RB-4, RB-5) y las eliminaciones sean lógicas con confirmación previa; (2) ninguna prueba de seguridad evidencie hallazgos críticos (inyección SQL, XSS, CSRF o fuga de datos entre empresas); (3) los tiempos de respuesta cumplan los umbrales de NFR-PERF (CRUD menor a 300 ms, carga de página menor a 2 s, subida/descarga de documentos menor a 10 s); (4) las validaciones de campos y reglas de negocio se apliquen tanto en el frontend como en el backend; y (5) la interfaz cumpla criterios básicos de accesibilidad validados con usuarios representativos, incluidos adultos mayores.

3.4 Herramientas utilizadas

Se utilizarán Postman y Swagger UI para probar y documentar los endpoints REST; Jest y Supertest para pruebas unitarias y de integración del backend; Cypress para pruebas end-to-end del frontend; OWASP ZAP para pruebas de penetración y detección de vulnerabilidades (CSRF, XSS, SQL Injection); y k6 o JMeter para simular carga concurrente y medir tiempos de respuesta bajo el umbral definido en NFR-PERF.

Adicionalmente, se requieren los siguientes recursos para la correcta ejecución de las pruebas:

- Recursos humanos: un analista QA (diseño y ejecución de pruebas), un desarrollador backend y uno frontend (soporte y corrección de defectos), un analista de seguridad (pruebas de penetración) y un representante de negocio (validación de criterios de aceptación).
- Recursos técnicos: Postman/Swagger UI, Jest + Supertest, Cypress, OWASP ZAP, k6/JMeter, navegadores actualizados (últimas 2 versiones de Chrome, Firefox, Safari y Edge) y dispositivos móviles/tablets para pruebas de responsividad.
- Entorno de prueba: ambiente de desarrollo local (Docker con PostgreSQL), ambiente de QA aislado con datos de prueba anonimizados, y ambiente de staging previo a producción para pruebas de carga y aceptación final.

4. Diseño de casos de prueba

Caso de prueba N.° 1

ID	NOMBRE	REQUERIMIENTO
CP-01	Login exitoso con credenciales válidas	RF-1.1
DESCRIPCIÓN		
Verificar que un usuario registrado pueda autenticarse correctamente con su nombre de usuario y contraseña, generando un token de sesión (JWT).		
PRECONDICIONES		

El usuario ya está registrado y su cuenta está activa. El backend y la base de datos PostgreSQL están disponibles.
PASOS
1. Acceder a la página de Login. 2. Ingresar nombre de usuario y contraseña válidos. 3. Presionar "Iniciar sesión".
RESULTADO ESPERADO
El sistema valida las credenciales, genera un JWT de corta vigencia y un refresh token, y redirige al usuario al Dashboard correspondiente a su rol.
CRITERIO DE ACEPTACIÓN
El login se completa en menos de 300 ms (NFR-PERF-1), se genera un token de sesión válido y el usuario accede solo a las funcionalidades permitidas según su rol.
DATOS DE PRUEBA
usuario: jperez / contraseña: Atlas#2026Segura
TIPO DE PRUEBA
Funcional (autenticación)

Caso de prueba N.° 2

ID	NOMBRE	REQUERIMIENTO
CP-02	Registro de usuario y creación de empresa	RF-2.1 / RF-2.2 / RF-2.3
DESCRIPCIÓN		
Verificar que un usuario nuevo pueda registrarse, crear una empresa y que se le asigne automáticamente el rol de administrador por ser el primer usuario de dicha empresa.		
PRECONDICIONES		
El correo electrónico a utilizar no debe estar previamente registrado en el sistema.		
PASOS		
1. Acceder al flujo de Registro. 2. Ingresar usuario, contraseña (12 caracteres, mayúscula, minúscula, número y símbolo) y correo. 3. Confirmar registro. 4. Completar el formulario de creación de empresa (nombre, dirección, teléfono, correo).		
RESULTADO ESPERADO		
El sistema crea el usuario con contraseña hasheada (bcrypt), crea la empresa asociada y asigna al usuario el rol "administrador" por defecto.		
CRITERIO DE ACEPTACIÓN		
El usuario visualiza el Dashboard de la empresa recién creada y puede acceder a las opciones de administración (usuarios, clientes, contratos).		
DATOS DE PRUEBA		
usuario: mgonzalez / correo: mgonzalez@empresa.cl / contraseña: Empresa#2026 / empresa: "Soluciones del Valle SpA"		
TIPO DE PRUEBA		
Funcional (registro y gestión de usuarios)		

Caso de prueba N.° 3

ID	NOMBRE	REQUERIMIENTO
CP-03	Restricción de acceso del rol Editor	RF-3.2 / RB-4
DESCRIPCIÓN		
Verificar que un usuario con rol "editor" no pueda crear, editar ni eliminar clientes o contratos, limitándose solo a la visualización.		
PRECONDICIONES		
Existe un usuario con rol "editor" asignado dentro de una empresa, y existen clientes/contratos previamente cargados.		
PASOS		
1. Iniciar sesión con un usuario de rol editor. 2. Intentar acceder a "Eliminar cliente" o "Editar contrato" desde la interfaz. 3. Intentar invocar directamente el endpoint DELETE/PUT correspondiente vía API.		
RESULTADO ESPERADO		
El sistema deniega la operación tanto en el frontend (opciones deshabilitadas u ocultas) como en el backend (respuesta HTTP 403 Forbidden), permitiendo solo operaciones de lectura (GET).		
CRITERIO DE ACEPTACIÓN		
Ningún intento de escritura del rol editor se ejecuta ni queda reflejado en la base de datos; el intento queda registrado en auditoría.		
DATOS DE PRUEBA		
usuario editor: aeditor@empresa.cl / recurso objetivo: cliente ID 105		
TIPO DE PRUEBA		
Seguridad (control de acceso por rol)		

Caso de prueba N.° 4

ID	NOMBRE	REQUERIMIENTO
CP-04	Aislamiento de datos entre empresas (multiempresa)	RB-2
DESCRIPCIÓN		
Verificar que un usuario de la Empresa A no pueda visualizar ni modificar clientes, contratos o usuarios pertenecientes a la Empresa B.		
PRECONDICIONES		
Existen al menos dos empresas registradas (Empresa A y Empresa B), cada una con usuarios y clientes propios.		
PASOS		
1. Iniciar sesión como usuario de la Empresa A. 2. Intentar acceder a GET /api/empresas/:id/clients usando el ID de la Empresa B. 3. Intentar acceder a la URL de un contrato de la Empresa B modificando el ID en la solicitud.		
RESULTADO ESPERADO		
El sistema responde con error de autorización (403) y no expone ningún dato de la Empresa B.		
CRITERIO DE ACEPTACIÓN		

No se filtra información de otra empresa bajo ninguna circunstancia; el intento queda registrado en el log de auditoría.
DATOS DE PRUEBA
token JWT de un usuario de la Empresa A / ID de un cliente perteneciente a la Empresa B
TIPO DE PRUEBA
Seguridad (aislamiento multiempresa)

Caso de prueba N.° 5

ID	NOMBRE	REQUERIMIENTO
CP-05	Cálculo automático del estado del contrato	RF-5.4
DESCRIPCIÓN		
Verificar que el sistema calcule y muestre correctamente el estado del contrato (activo, vence o expirado) según la fecha de inicio y de término.		
PRECONDICIONES		
Existen contratos registrados con distintas fechas de inicio y término.		
PASOS		
1. Crear un contrato con fecha de término próxima a vencer (dentro de 5 días). 2. Consultar el listado de contratos. 3. Repetir con un contrato ya vencido y uno vigente por varios meses.		
RESULTADO ESPERADO		
El sistema muestra "vence" para el contrato próximo a vencer, "expirado" para el vencido y "activo" para el vigente, sin intervención manual.		
CRITERIO DE ACEPTACIÓN		
El estado mostrado coincide en el 100% de los casos con la fecha actual del sistema comparada contra la fecha de término.		
DATOS DE PRUEBA		
Contrato 1: inicio 01/01/2026, término 12/09/2026 (hoy 08/09/2026). Contrato 2: término 01/08/2026. Contrato 3: término 01/03/2027		
TIPO DE PRUEBA		
Funcional (lógica de negocio)		

Caso de prueba N.° 6

ID	NOMBRE	REQUERIMIENTO
CP-06	Rendimiento en carga y descarga de documentos	RF-5.2 / RF-5.3 / NFR-PERF-1
DESCRIPCIÓN		
Verificar que la subida y descarga de un documento adjunto a un contrato se completen dentro del tiempo máximo definido.		
PRECONDICIONES		
El usuario tiene permisos de administrador o editor con acceso al contrato; el archivo cumple con los formatos permitidos (PDF, DOC, PPT, JPG, PNG).		

PASOS
1. Seleccionar un contrato existente. 2. Adjuntar un documento de tamaño representativo (ej. 5 MB) en formato PDF. 3. Confirmar la subida y luego descargar el mismo documento.
RESULTADO ESPERADO
El documento se almacena en el storage interno, queda referenciado en la base de datos, y tanto la subida como la descarga se completan sin errores.
CRITERIO DE ACEPTACIÓN
El tiempo total de subida y de descarga no supera los 10 segundos cada uno, bajo condiciones de red estándar.
DATOS DE PRUEBA
archivo "contrato_anexo.pdf" (5 MB)
TIPO DE PRUEBA
No funcional (rendimiento)

Caso de prueba N.° 7

ID	NOMBRE	REQUERIMIENTO
CP-07	Accesibilidad para usuarios adultos mayores	NFR-USAB-1 / NFR-USAB-4
DESCRIPCIÓN		
Verificar que la interfaz cumpla criterios básicos de accesibilidad y que el flujo de acceso a la información (cliente → contratos) sea claro para usuarios adultos mayores.		
PRECONDICIONES		
Existe un ambiente de pruebas con datos cargados; se cuenta con un grupo de usuarios representativos, incluyendo adultos mayores.		
PASOS		
1. Solicitar a un usuario representativo que inicie sesión y navegue hasta los contratos de un cliente específico. 2. Observar si logra completar el flujo sin ayuda. 3. Verificar tamaño de fuente, contraste y navegación por teclado.		
RESULTADO ESPERADO		
El usuario completa el flujo cliente → contratos sin bloqueos mayores; la interfaz cumple con tipografía legible, contraste adecuado y navegación por teclado funcional		
CRITERIO DE ACEPTACIÓN		
Al menos 5 usuarios representativos (incluidos adultos mayores) completan el flujo sin errores críticos ni asistencia externa.		
DATOS DE PRUEBA		
Grupo de prueba: 5 usuarios (2 adultos mayores), flujo: Login → Clientes → Detalle cliente → Contratos.		
TIPO DE PRUEBA		
No funcional (usabilidad)		

5. Cierre / análisis de cobertura

El plan de pruebas diseñado cubre de manera transversal los requerimientos funcionales (RF-1 a RF-6) y no funcionales (NFR-SEG, NFR-PERF, NFR-USAB) definidos en el ERS de Atlas. Los siete casos de prueba abarcan autenticación, gestión de usuarios y empresas, control de acceso por rol, aislamiento multiempresa, lógica de negocio (estado de contratos), rendimiento en manejo de documentos y usabilidad para usuarios adultos mayores. Se considera que la cobertura es adecuada y coherente con los objetivos del proyecto, dado que prioriza los flujos críticos de negocio, los controles de seguridad exigidos por la normativa chilena de protección de datos (Ley N.º 19.628 y N.º 21.719), y los estándares técnicos ISO/IEC 25010 e ISO/IEC 27001. Se recomienda ampliar en futuras iteraciones la cobertura de pruebas de compatibilidad entre navegadores y dispositivos móviles, dado que actualmente no cuentan con un caso de prueba dedicado.